Записки программиста

Блог о программировании, а также электронике, радио, и всяком таком

Использование PGP/GPG, руководство для нетерпеливых

23 ноября 2016

Данная статья представляет собой краткое руководство по использованию GnuPG (он же GPG). В ней вы найдете основные команды, примеры использования, а также инструкции по прикручиванию GPG к почтовым клиентам. Далее предполагается, что вы знакомы с принципом работы GPG и объяснять, например, что такое ассиметричная криптография, открытый и закрытый ключ, цифровая подпись и так далее, не требуется. За несколько десятилетий существования GPG никто особо не преуспел в его взломе, что как бы намекает нам, что это довольно надежное решение как для обмена зашифрованными сообщениями, так и просто шифрования файлов.

Терминология

Существует некоторая путаница в терминологии. Например, далеко не все могут внятно объяснить, чем PGP отличается от GPG. Давайте же во всем разберемся.

- **OpenPGP** — стандарт шифрования, описанный в RFC 4880 и RFC 6637. Не следует путать с конкретными реализациями, такими, как PGP и GPG;
- **GnuPG** или **GPG** — конкретная открытая (GPLv3) реализация OpenPGP, речь о которой пойдет в настоящей статье;
- **PGP** — сильно проприетарная реализация OpenPGP от компании PGP Corporation. В 2010-м году компанию купила Symantec, а ее продукты переименовала во что-то типа Symantec Desktop Email Encryption;

Часто, говоря «PGP», люди имеют в виду способ шифрования, описанный в OpenPGP, и соответственно любую из его реализаций.

Основные команды GnuPG

Генерируем ключи:

```
gpg --gen-key
```

Хорошей идеей будет выбрать алгоритм RSA и длину ключей 4096 бит.

Важно! Не забудьте пароль от закрытого ключа.

Частая проблема — сообщение вроде такого:

```
Not enough random bytes available.  Please do some other work to give
the OS a chance to collect more entropy! (Need 204 more bytes)
```

Решается она установкой демона для сбора энтропии:

```
sudo apt-get install rng-tools
```

Просмотр списка ключей:

```
gpg --list-keys
gpg --list-secret-keys
gpg --list-public-keys
```

Получение fingerprint ключа:

gpg --fingerprint afiskon@example.ru

Пример вывода:

```
pub   4096R/8640D6B9 2016-09-27
      Fingerprint = DB5E AA39 0745 427D ED31  D189 3197 3F00 8640 D6B9
uid                  Aleksander Alekseev <afiskon@example.ru>
sub   4096R/5982B4BF 2016-09-27
```

Fingerprints используются в основном для проверки того, что с сервера ключей (см далее) был импортирован действительно правильный ключ. Для поиска их не используют.

Для отображения более безопасных длинных id используйте опцию keyid-format:

```
gpg --keyid-format LONG --list-keys
gpg --keyid-format 0xLONG -k 7EFE74E5
```

Короткие keyid удобны для манипуляции с ключами локально. Для поиска всегда следует использовать длинные id и проверять fingerprints. В последних версиях GPG длинные id используются по умолчанию.

Удалить ключ:

```
gpg --delete-secret-keys 8640D6B9
gpg --delete-keys 8640D6B9
```

Экспорт открытого ключа в текстовом виде (можно писать на всех заборах):

```
gpg --armor --output pubkey.txt --export 8640D6B9
```

Экспорт закрытого ключа в текстовом виде (ключ все еще зашифрован мастер-паролем, можно использовать для бэкапа в Git):

```
gpg --armor --output privkey.txt --export-secret-keys 8640D6B9
```

Импорт открытого ключа:

```
gpg --import key.txt
```

Импорт закрытого ключа:

```
gpg --allow-secret-key-import --import privkey.txt
```

Если не указать `--allow-secret-key-import`, импортируется только открытый ключ, и при попытке подписать что-то вы будете получать странные ошибки вроде:

```
gpg: no default secret key: secret key not available
gpg: msg.txt: sign+encrypt failed: secret key not available
```

Экспорт открытого ключа на keyserver:

```
gpg --keyserver pgp.mit.edu --send-keys 8640D6B9
```

Важно! После того, как вы залили ключ на keyserver, его будет невозможно удалить, только сделать revoke. Убедитесь, что вы сделали надежную резервную копию ключа. Если вы раньше никогда не работали с PGP/GPG, *очень* советую сначала потренироваться на почтовых адресах в зоне example.ru.

Не имеет большого значения, какой keyserver указать. Например, еще есть keys.gnupg.net, а также другие. Все они время от времени обмениваются друг с другом данными. Не лишено смысла сделать `send-keys` сразу на несколько серверов, чтобы их быстрее увидели все пользователи PGP/GPG. Синхронизация серверов, по моим наблюдениям, занимает минут 10-15.

Hint: чтобы постоянно не указывать `--keyserver`, просто допишите в ~/.bashrc:

```
alias gpg="gpg --keyserver pgp.mit.edu"
```

Импорт открытого ключа с keyserver:

gpg --keyserver pgp.mit.edu --search-keys afiskon@example.ru

В мире PGP/GPG существуют так называемая сеть доверия (web of trust). В двух словах это означает, что GPG не доверяет ключу, если только он не подписан кем-то, кому вы доверяете. Кроме того, если вы доверяете Пете, а Петя доверяет Коле, то вы автоматически доверяете Коле. В частности, по умолчанию при проверке подписи и прочих действиях GPG будет ругаться так:

```
WARNING: This key is not certified with a trusted signature!
      There is no indication that the signature belongs to
      the owner.
```

Чтобы исправить это, говорим:

gpg --edit-key afiskon@example.ru

Затем в диалоге говорим `trust`, жмем 5 («I trust ultimately»), говорим `quit`. Другие ключи можно подписать командой `tsign`. Кстати, там же можно сменить пароль от вашего ключа (команда `passwd`), изменить дату экспирации ключа в любую сторону (команда `expire`), добавить имя/email (команда `adduid`), удалить имя/email (команда `revuid`), посмотреть алгоритмы шифрования, используемые по умолчанию (`showpref`) и делать другие интересные вещи.

Примечание: Что делать, когда ключ заэкспайрился? В этом случае можно изменить дату экспирации на более позднюю и перезалить ключ. Или же создать новый ключ, подписать его старым, и залить новый ключ на keyserver. Делать revoke не требуется.

Вы можете подписать чей угодно ключ и залить подписанный ключ на сервер, подтвердив тем самым, что ключ действительно принадлежит человеку, указанному в описании:

gpg --sign-key 7EFE74E5
gpg --keyserver pgp.mit.edu --send-keys 7EFE74E5

На какой-нибудь другой машине можно скачать ключ заново и посмотреть, кем он подписан:

gpg --keyserver pgp.mit.edu --search-keys eax@example.ru
gpg --list-sigs eax@example.ru
gpg --check-sigs eax@example.ru

Время от времени стоит обновлять ключи, на случай, если у ключей появились новые подписи, или какие-то ключи отозвали:

gpg --keyserver pgp.mit.edu --refresh-keys

Пример шифрования и подписи файла для заданного получателя (ключ -r можно указывать много раз):

gpg --encrypt --sign --armor -r eax@example.ru msg.txt

Расшифровка файла и проверка подписи осуществляется командой:

gpg msg.txt.asc

Пример подписи и проверки подписи бинарного файла (например, ISO образа диска):

gpg --detach-sign file.iso
gpg --verify file.iso.sig

Симметричное шифрование/дешифрование файла (удобно, например, для хранения паролей):

gpg -o nonsense.gpg --cipher-algo AES -a -c nonsense.txt
gpg -o nonsense2.txt -d nonsense.gpg

Симметричное шифрование с сохранением в бинарном формате (удобно для шифрования бэкапов):

```
tar -cvzf - /home/eax | \
  gpg --symmetric --cipher-algo AES256 --digest-algo SHA256 \
  --compression-algo Uncompressed > backup.tgz.gpg
```

Расшифровка зашифрованного таким образом файла:

```
gpg --decrypt backup.tgz.gpg | tar -xvzf -
```

При этом по умолчанию GPG запрашивает пароль через GUI интерфейс, что я лично нахожу не очень-то удобным. Изменить данное поведение можно так:

```
echo 'pinentry-program /usr/bin/pinentry-tty' >> \
  ~/.gnupg/gpg-agent.conf
killall gpg-agent
```

Может оказаться, что ваш закрытый ключ скомпрометирован, то есть, его украли и подобрали к нему пароль. Или же вы потеряли его. Или просто не можете вспомнить пароль от ключа. Для таких случаев предусмотрен отзыв ключа. Делается это так. Заранее, сразу после создания ключей, требуется создать сертификат отзыва:

```
gpg --gen-revoke --armor --output=revocation.crt eax@example.ru
```

Используя его, ключ можно отозвать так:

```
gpg --import revocation.crt
gpg --keyserver pgp.mit.edu --send-keys 7EFE74E5
```

Важно! Сертификат отзыва не шифруется и может быть использован кем угодно. Убедитесь, что храните его в надежном месте (лучше даже в нескольких таких местах) и непременно в зашифрованном виде!

Прикручиваем GnuPG к Claws Mail

В Ubuntu нам понадобятся следующие пакеты:

```
sudo apt-get install claws-mail-pgpinline claws-mail-pgpmime
```

В Configuration → Plugins → Load загружаем pgpcore.so, pgpinline.so и pgpmime.so. Далее просто настраиваем плагины через настойки клиента. В настройках аккаунта можно указать, какие ключи использовать, а также сгенерировать новые ключи и отправить их на keyserver. При написании письма в Options станут доступны галочки Encrypt и Sign.

В свойствах аккаунта во вкладке Privacy можно настроить плагины так, чтобы сообщения всегда подписывались, шифровались при ответе на зашифрованные сообщения, и так далее. Использовать советую PGP/MIME, так как PGP/Inline может не слабо раздражать пользователей, не использующих PGP/GPG. То есть, почти всех.

Из косяков плагина я столкнулся только с тем, что в настройках нужно указать полный путь к исполняемому файлу gpg, после этого все заработало.

Прикручиваем GnuPG к Mutt

Чтобы GPG заработал в Mutt, в ~/.muttrc дописываем:

```
# включаем поддержку GPG
set crypt_use_gpgme=yes

# по дэфолту подписывать все сообщения
set crypt_autosign=yes

# шифровать ответы на зашифрованные сообщения
set crypt_replyencrypt=yes
```

При написании письма жмем `p`, там выбираем опции — подписать, зашифровать, и так далее. Все опции `crypt_*` и `pgp_*` описаны в `man muttrc`. Плюс к этому здесь есть длинная строчка, благодаря которой Mutt можно научить проверять подписи для inline сообщений.

Мой полный и поддерживаемый в актуальном состоянии вариант конфига для Mutt находится здесь.

Заключение

GPG прикручивается еще очень много к чему. Скажем, для Thunderbird есть плагин Enigmail. Существуют мобильные приложения с поддержкой GPG. Например, для iPhone есть oPenGP и iPGMail. Кроме того, существуют плагины и для IM-клиентов, в частности, для Psi. К сожалению, рассмотреть их все в рамках одной статьи не представляется возможным.

В качестве домашнего задания можете добавить меня в свой keyring, подписать мои ключи и отправить мне на email зашифрованное письмо.

А используете ли вы PGP/GPG?

Дополнение: Также вас может заинтересовать статья Шифрование сообщений в Jabber при помощи OTR.

Метки: Безопасность, Криптография.

Комментарии к этой записи в настоящее время закрыты.

14 Comments Записки программиста Политика конфиденциальности Disqus 1 Войти

Favorite 5 Твитнуть Поделиться Новое

Leonid • 3 года назад

День добрый. Почему то перестал запускаться интерфейс программы KGPG. Пробовал и переустанавливать, но ни чего не выходит. Затем психанул и удалил все файлы из .gnupg, это не страшно? До сего момента не запускается KGPG и KLEOPATRA отказывается создавать пару ключей, ссылаясь на какую-то "общую ошибку".

Поделиться ›

maksim.yugai • 4 года назад

А кто где хранит бэкапы, private key? И вообще как правильно это делать?

Поделиться ›

Aleksander Alekseev Модератор → maksim.yugai • 4 года назад

Я на внешнем USB-носителе храню.

Поделиться ›

Андрей • 4 года назад

а что будет если gpg file.gpg ?

Поделиться ›

konty • 4 года назад

"За несколько десятилетий существования GPG никто особо не преуспел в его взломе, что как мы намекает нам..." Ошибка: исправить "МЫ" на "БЫ". За остальное спасибо.

Поделиться ›

Aleksander Alekseev Модератор → konty • 4 года назад

Благодарю, исправил.

1 Поделиться ›

Alexander Plaksin → Aleksander Alekseev • 4 года назад

а мне кажется главная ошибка не в "МЫ" на "БЫ" а в том, что-таки во взломе уже

преуспели:
https://efail.de/
• Поделиться ›

Максим Ястребов → Alexander Plaksin • 4 года назад
Нет: https://www.linux.org.ru/ne...
• Поделиться ›

Alexander Plaksin → Максим Ястребов • 4 года назад
Вы правы, оказалось больше истерики
• Поделиться ›

Mr. CaT • 4 года назад
в Общем то. статья классная мне очень понравилась. многое понял
• Поделиться ›

Mr. CaT • 4 года назад
извините, но вы написали --alow-secret-key-import вместо --allow-secret-key-import
• Поделиться ›

Aleksander Alekseev Модератор → Mr. CaT • 4 года назад
Исправил. Спасибо за бдительность!
1 • Поделиться ›

Alexandr • 5 лет назад
Чтобы не потерять, можно делать бэкап private key на бумагу: http://www.jabberwocky.com/...
1 • Поделиться ›

IC Rainbow • 5 лет назад • edited
А если добавить свой ключ на гитхаб и коммитить с `-S`, то коммиты будут иметь няшные беджики "verified".

https://help.github.com/art...
1 • Поделиться ›

Подписаться **Добавь Disqus на свой сайтДобавить DisqusДобавить** **Do Not Sell My Data**

- # Коротко о себе

Меня зовут Александр, позывной любительского радио R2AUK. Здесь я пишу об интересующих меня вещах и временами — просто о жизни.

Вы можете следить за обновлениями блога с помощью RSS, ВКонтакте, Twitter или Telegram. Сайт можно поддержать на Patreon.

Мой контактный e-mail — mail@eax.me. Если вы хотите мне написать, прошу предварительно ознакомиться с этим FAQ.

- Поиск

- ## Основные рубрики

  - Антенны
  - Беспроводная связь
  - C/C++
  - FPGA
  - Go
  - Linux
  - PostgreSQL
  - Python
  - Software Defined Radio
  - STM32
  - СУБД
  - Электроника

Liveinternet
сервис статистики

Копирование материалов данного сайта не возбраняется при условии указания ссылки на первоисточник. © 2009–2022 Записки программиста